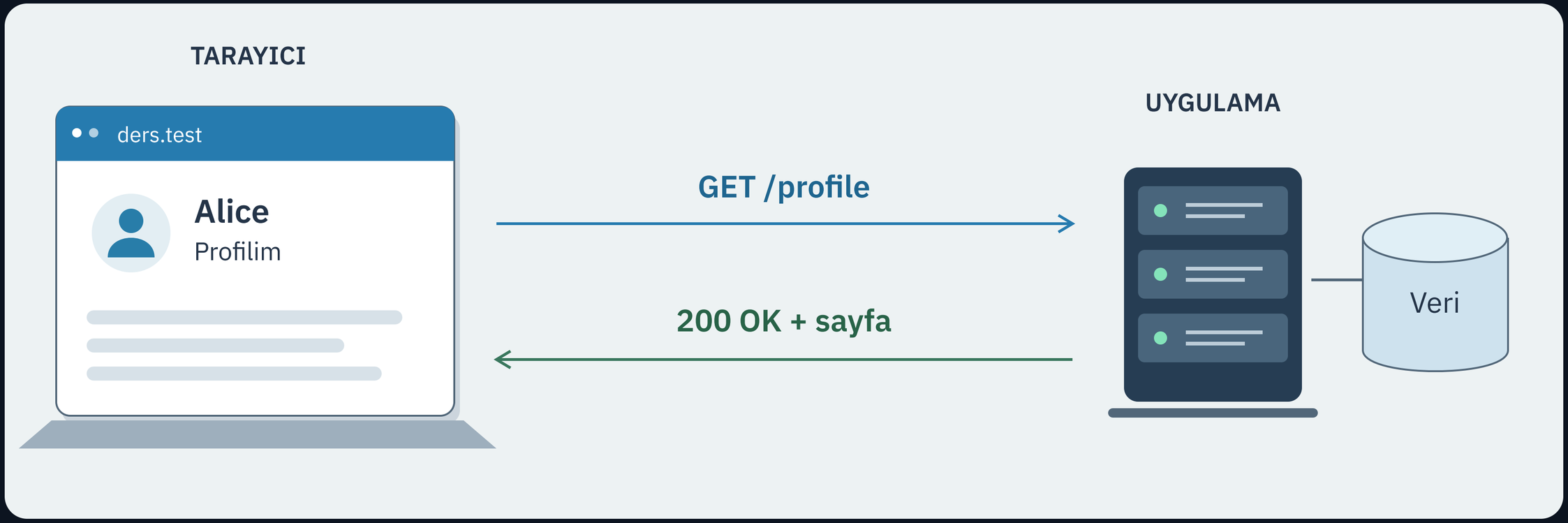
2026-27 GÜZ · HAFTA 3

Tarayıcı güvenliği

HTTP, oturumlar ve istemci tarafı saldırılar



BUGÜN

Önce normal akış, sonra saldırı

1 · Hatırlatma

SQLi
Command injection
Path traversal

→

2 · Normal akış

HTTP
Cookie ve session
Kimlik doğrulama

→

3 · XSS

Reflected
Stored
Savunma

Her örnekte: ne değişti, ne oldu, nasıl düzelir?

Üç hata, üç farklı kontrol

SQLi

1 OR 1=1

Sabit sorgu
+ ayrı parametre

COMMAND INJECTION

alice; echo DEMO

Shell yok
+ argüman listesi

PATH TRAVERSAL

../private/file

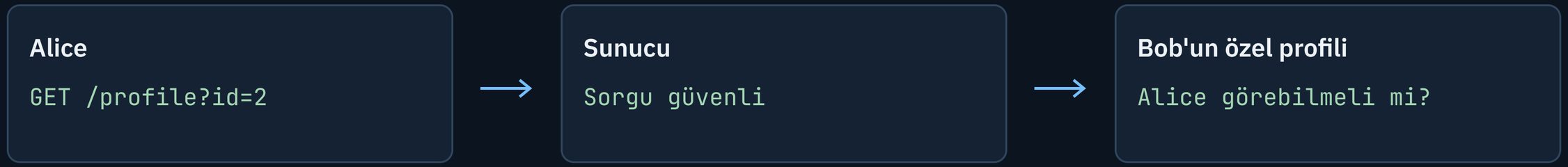
Yolu çöz
+ izinli dizini kontrol et

HAFTA 2 → HAFTA 3

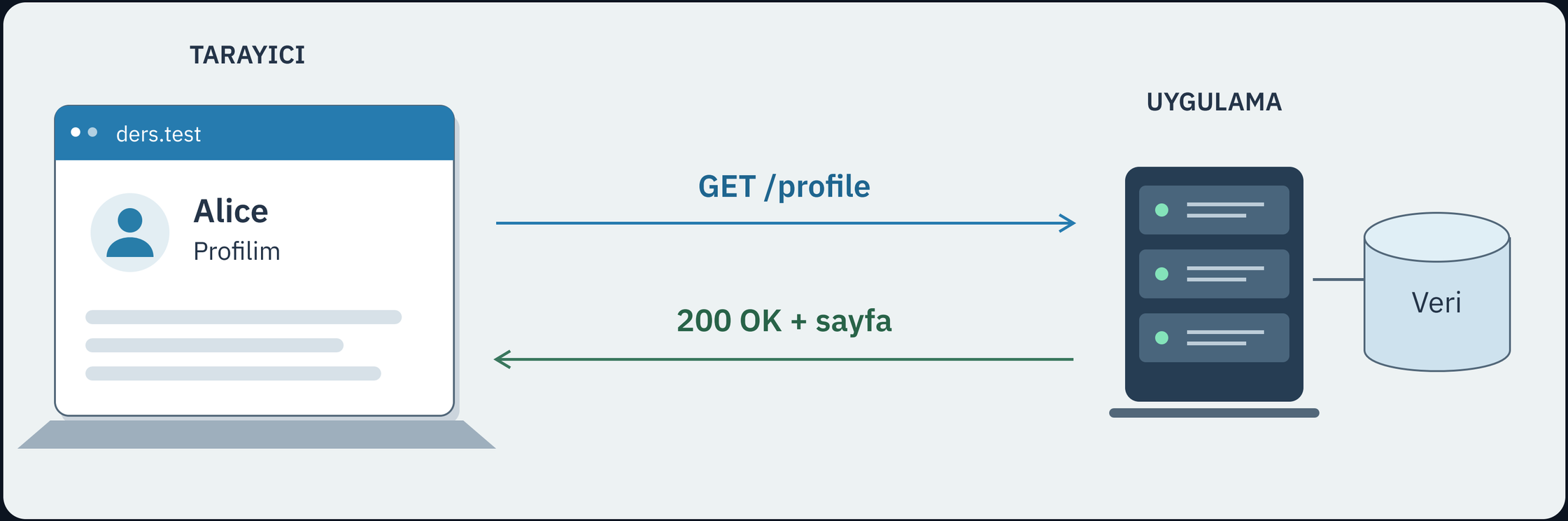
SQLi kapandı. Bu profil kimin?

Parametreli sorgu

```
1  db.execute("SELECT name FROM users WHERE id = ?", (uid,))
```



Client ister, sunucu yanıtlar



Client; tarayıcı, mobil uygulama veya curl olabilir.

İSTEMCİYE GÜVENME

Buton gizli olsa da istek gönderilebilir

ders.test/users

Sil butonu yok

Alice normal kullanıcı.

Şematik tarayıcı görünümü

Arayüz dışında gönderilen istek

```
1 DELETE /api/users/2 HTTP/1.1
2 Host: ders.test
```

İzin kontrolü sunucuda yapılır.

Adresin hangi kısmı nereye gider?

https://	ders.test	:443	/profile	?id=1	#details
scheme	host	port	path	query	fragment

Sunucuya giden yol ve query

`/profile?id=1`

Tarayıcıda kalan fragment

`#details`

HTTP · REQUEST

Bir giriş isteği

request.http

```
POST /login HTTP/1.1
Host: ders.test
Content-Type: application/x-www-form-urlencoded
Content-Length: 27

username=alice&password=lab
```

1 · İstek satırı

POST /login

2 · Header'lar

Host, içerik türü, uzunluk

3 · Boş satırdan sonra

Body: form değerleri

HTTP · RESPONSE

Yanıt: durum kodu + header + body

response.http

```
HTTP/1.1 200 OK
Content-Type: application/json
Cache-Control: no-store

{"name":"alice"}
```

200 · Başarılı

Profil verisi döner.

401 · Geçerli kimlik bilgisi yok

Kimlik doğrulaması gerekir.

403 · İzin yok

İşlem yapılmaz.

Her durum kodu hata değildir

1xx	Informational	Ara bilgi	100 · 103
2xx	Successful	Başarılı	200 · 201 · 204
3xx	Redirection	Yönlendirme / önbellek	301 · 303 · 304
4xx	Client Error	İstekle ilgili ret	400 · 401 · 404
5xx	Server Error	Sunucu işlemi tamamlayamadı	500 · 502 · 503

Kod, HTTP yanıtındadır. İlk rakam sınıfı söyler; ayrıntıyı tam kod belirler.

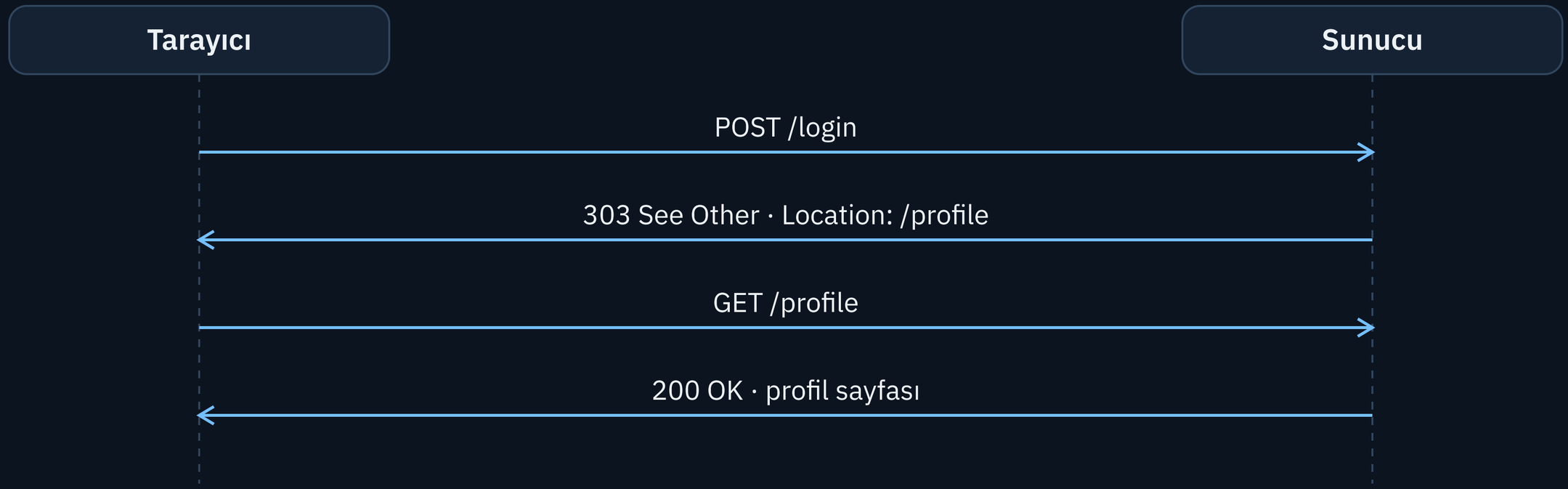
HTTP · 2xx · SUCCESSFUL

Başarılı, oluşturuldu, sıraya alındı, boş yanıt

200	**OK** İstek başarılı	→	GET /profile → profil verisi
201	**Created** Yeni kaynak oluşturuldu	→	POST /notes → /notes/42
202	**Accepted** Kabul edildi; henüz bitmedi	→	POST /reports → iş sıraya alındı
204	**No Content** Başarılı; gövde yok	→	DELETE /notes/42 → boş yanıt

202 tamamlandı demek değildir. 204'te JSON gövdesi bekleme.

303: işlemi gönder, sonuç sayfasını aç



304 Not Modified farklıdır: önbellekteki kopyayı kullan; yeni gövde gelmez.

HTTP · 4xx · CLIENT ERROR

İstek, adres, metot veya süre

400	**Bad Request** Geçersiz istek	→ Bozuk JSON: {"theme":
404	**Not Found** Kaynak bulunamadı	→ GET /notes/999 → kayıt yok
405	**Method Not Allowed** Bu metot burada desteklenmiyor	→ POST /profile → yalnız GET var
408	**Request Timeout** İstek zamanında tamamlanmadı	→ Sunucu isteğin kalanını bekledi

405 yanıtındaki Allow, desteklenen metotları belirtir; örnek: Allow: GET, HEAD.

Kimlik bilgisi eksik mi, erişim mi yasak?

GET /admin · aynı kaynak

Geçerli kimlik bilgisi yok

401 **Unauthorized**

Önce kimliğini doğrula.

GET /admin · aynı kaynak

Alice · normal kullanıcı

403 **Forbidden**

Bu işleme izin yok.

401: kimlik doğrulama eksik. 403: sunucu erişimi reddediyor.

401 yanıtı WWW-Authenticate taşır. 403 almak, mutlaka giriş yapılmış demek değildir.

Geçerli biçim, kabul edilebilir işlem demek değil

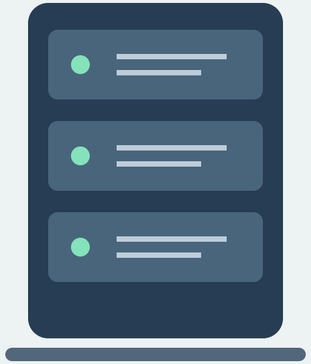
409	**Conflict** Kaynağın durumuyla çakışma	→	Aynı kullanıcı adı zaten kayıtlı
422	**Unprocessable Content** Biçim doğru; içerik işlenemiyor	→	JSON geçerli, yaş değeri negatif
413	**Content Too Large** İstek gövdesi çok büyük	→	2 MB sınırına 20 MB dosya
415	**Unsupported Media Type** İçerik türü desteklenmiyor	→	JSON endpoint'ine XML gönderildi

400 / 422 seçimini API sözleşmesinde tutarlı yap; istemciye neyi düzelteceğini söyle.

HTTP · 5xx · SERVER ERROR

Sunucu isteği tamamlayamadı

500 Internal Server Error

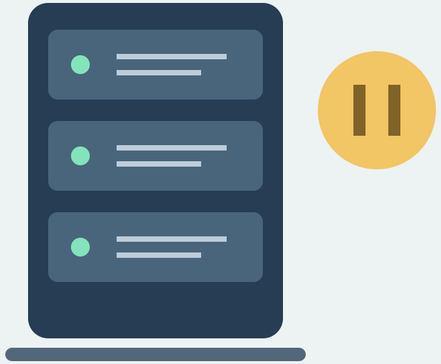


İstek geldi.
Kod hata verdi.

Örnek: yakalanmayan exception

Beklenmeyen uygulama hatası

503 Service Unavailable



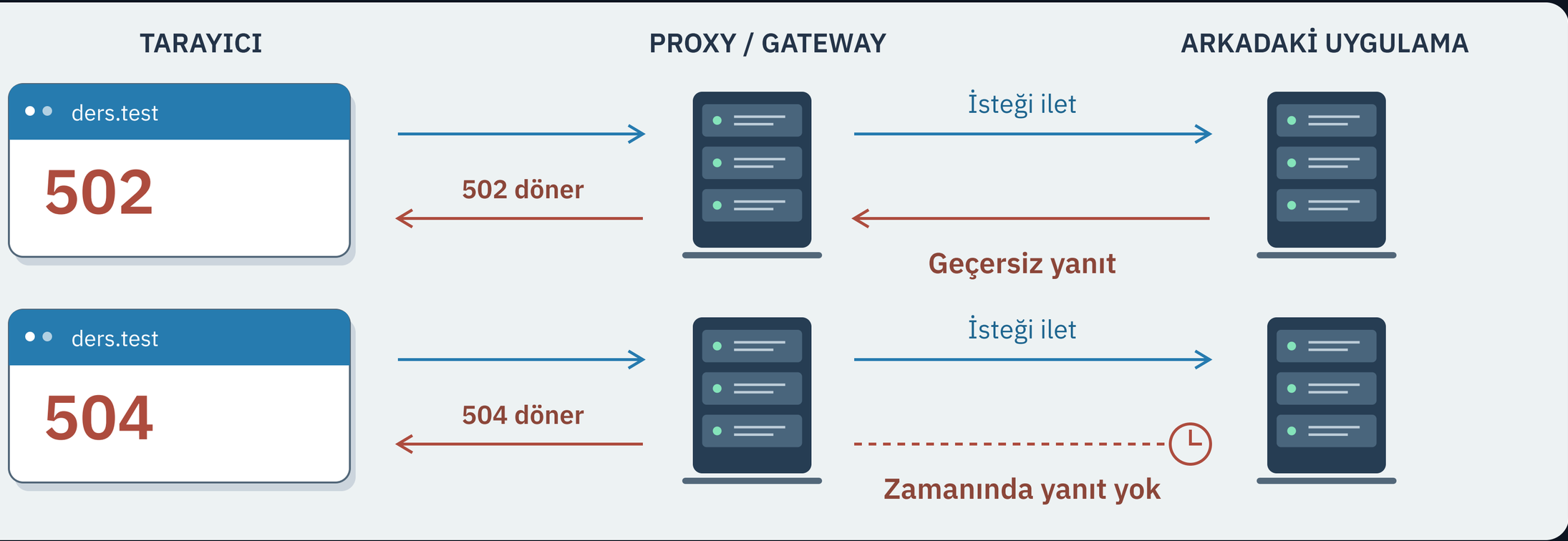
Şu an hizmet veremiyorum.

Örnek: planlı bakım

Bakım veya geçici aşırı yük

501: gereken işlev desteklenmiyor. 505: HTTP ana sürümü desteklenmiyor.

Aradaki sunucu da hata döndürebilir



502 Bad Gateway: geçersiz upstream yanıtı. 504 Gateway Timeout: beklenen yanıt yetişmedi.

HTTP · 429 / 503 · TEKRAR DENEME

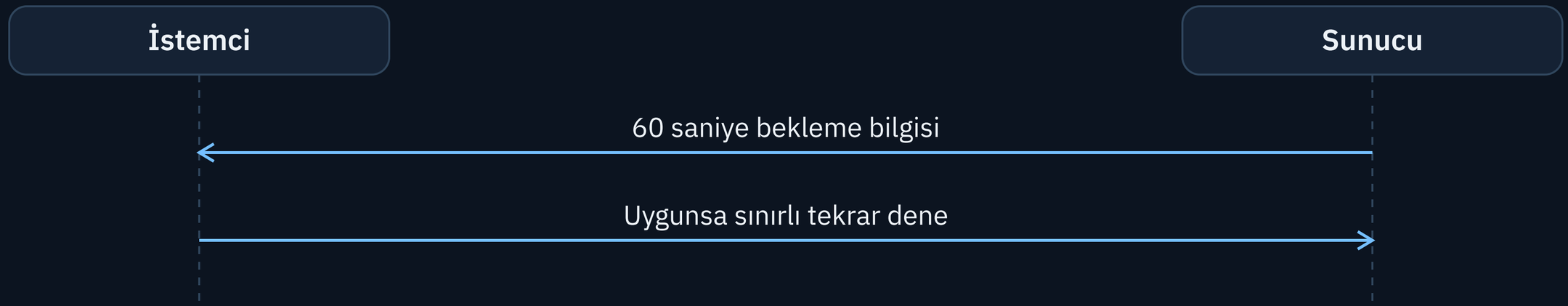
Çok istek göndermek, hatayı büyütebilir

İstek hız sınırı aşıldı

```
1 HTTP/1.1 429 Too Many Requests
2 Retry-After: 60
```

Hizmet geçici olarak verilemiyor

```
1 HTTP/1.1 503 Service Unavailable
2 Retry-After: 60
```



Özellikle 504 sonrası POST'u körlemesine tekrarlama: ilk işlem yapılmış olabilir.

HTTP · GÜVENLİ HATA YANITI

Kullanıcıya kısa mesaj, sunucuya teşhis kaydı

İstemcinin gördüğü · kısaltılmış yanıt

```
HTTP/1.1 500 Internal Server Error
Content-Type: application/json
Cache-Control: no-store

{"error":"internal_error",
 "request_id":"r-42"}
```

Erişimi kısıtlı sunucu logu

```
request_id=r-42
route=/profile
status=500
exception=DatabaseUnavailable
```

Stack trace, SQL sorgusu, cookie ve gizli anahtarları yanıta koyma.

GET okur; POST işlem başlatır

Profili getir

```
GET /profile
```

Temayı değiştir

```
POST /settings/theme

theme=light
```

Metot seçimi, kimlik ve izin kontrolünün yerini tutmaz.

HTTPS

Ağdaki aktarımı TLS korur



DevTools içeriği gösterir; tarayıcı bağlantının ucudur.

HTTP · STATELESS

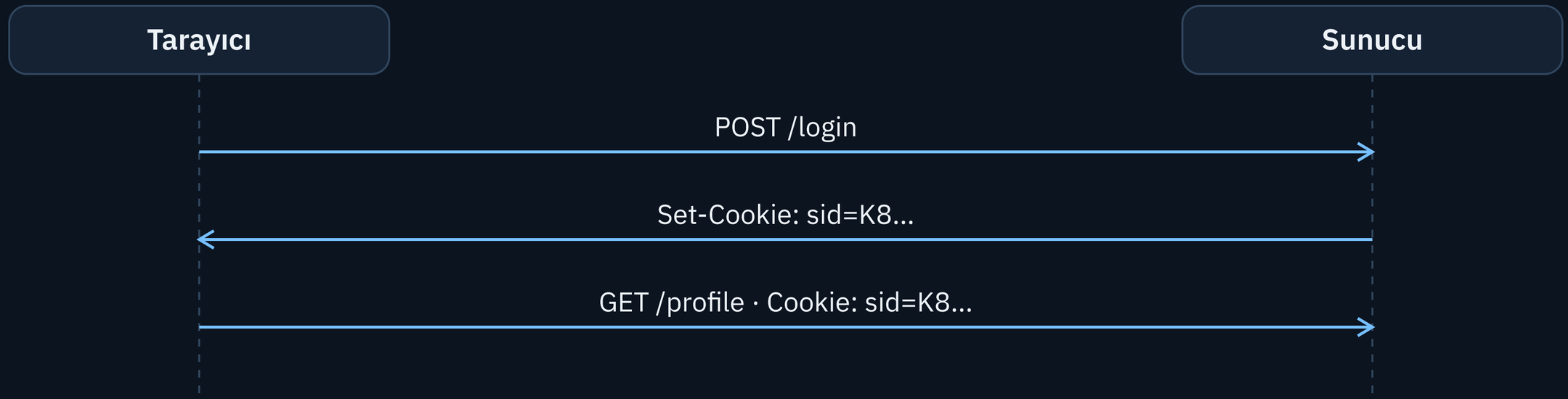
İkinci isteğin Alice’ten geldiğini nasıl anlarız?



HTTP, önceki giriş bilgisini kendiliğinden hatırlamaz.

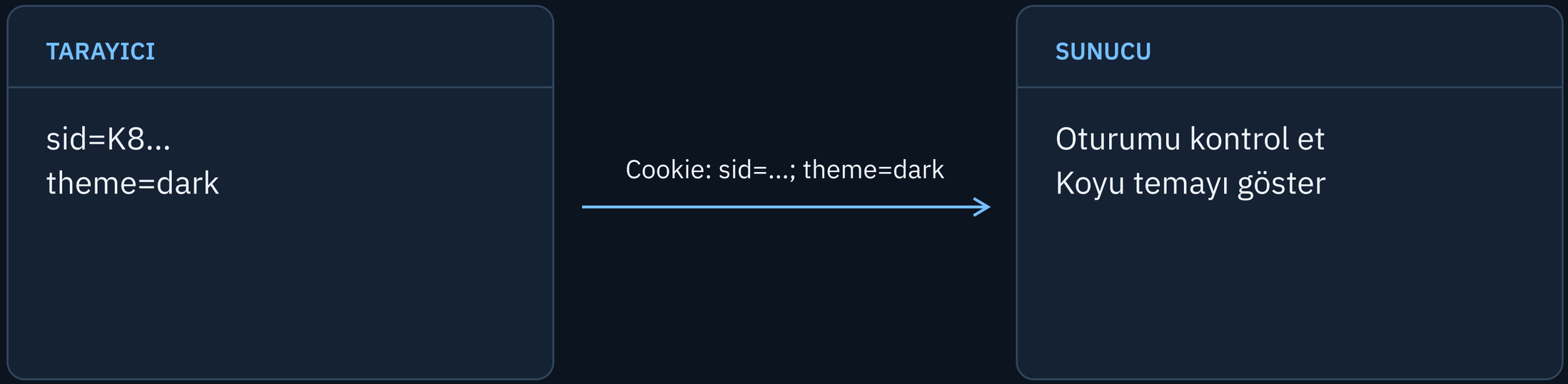
COOKIE

Yanıtta kaydet, sonraki istekte gönder

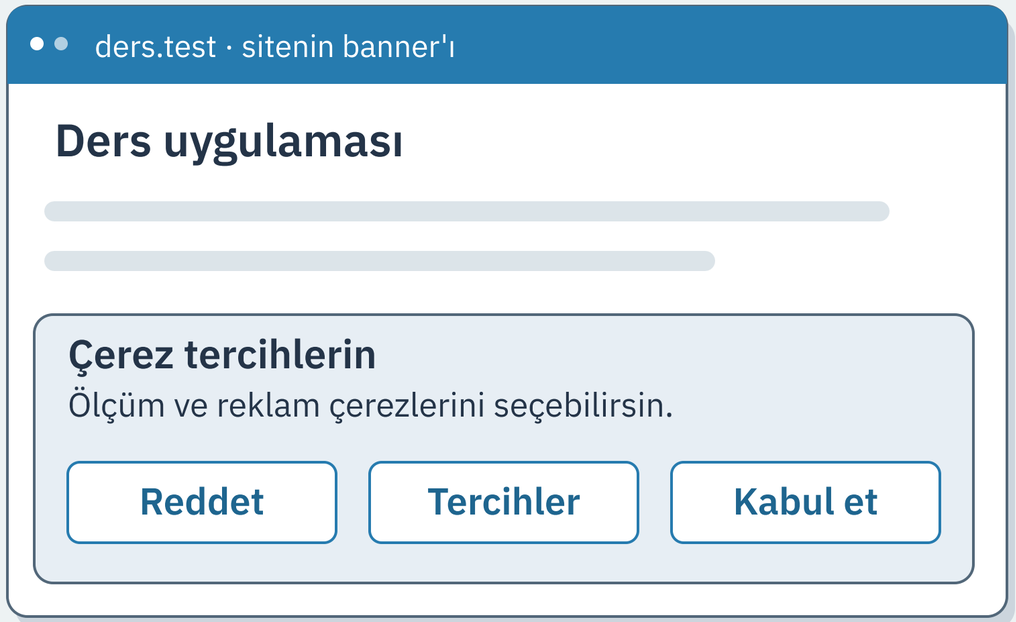


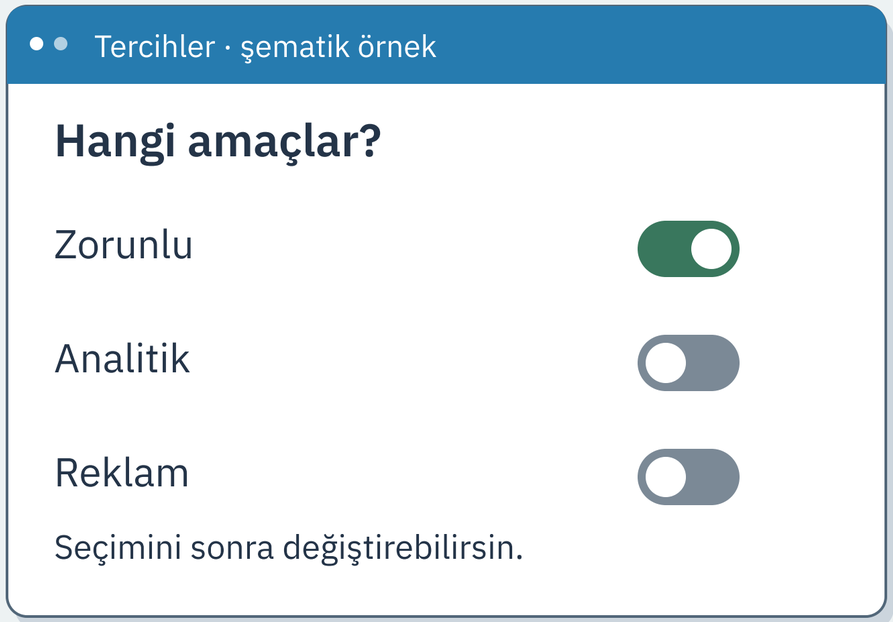
K8… gösterim için kısaltılmış rastgele oturum kimliği.

Cookie yalnızca oturum için kullanılmaz



“Kabul et” dediğimizde neyi seçiyoruz?

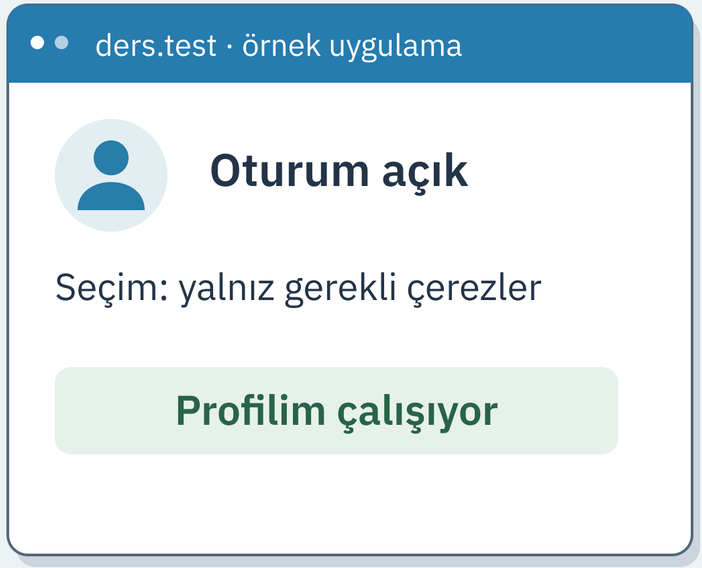




Bu örnekte analitik ve reklam isteğe bağlı; seçimden önce kapalı.

ÇEREZ İZİNLERİ

“Reddet” demek, oturumu kapatmak değildir



BU ÖRNEKTE TARAYICIDA

sid=K8…	Giriş için gerekli
consent=necessary	Tercihi hatırlar
ad_id=T42	Reklam çerezi yok

Reddet: bu sitenin isteğe bağlı çerezlerini reddetmek. Tüm çerezleri silmek değil.

ÜÇÜNCÜ TARAF ÇEREZİ

İki farklı sitede aynı reklam hizmeti



Tarayıcı bu kullanımı engelleyebilir veya siteye göre ayırabilir.

İKİ AYRI KONTROL

Siteye izin verdim; tarayıcı yine engelleyebilir



Sitenin banner'ı tarayıcının güvenlik ayarını değiştirmez.

Üç ayar, üç farklı görev

Secure

HTTPS ile gönder

Ağdaki aktarım

HttpOnly

JavaScript okumasın

Cookie'ye script erişimi

SameSite

Site dışını sınırla

İsteğe cookie eklenmesi

HTTPS yanıtı

```
1 Set-Cookie: sid=K8...; Secure; HttpOnly; SameSite=Lax; Path=/
```

COOKIE · KAPSAM

Path gönderimi daraltır, uygulamaları ayırmaz

ders.test yanıtı

```
1 Set-Cookie: theme=dark; Path=/course
```

ders.test/course

Cookie gönderilir

Path eşleşiyor.

Şematik tarayıcı görünümü

ders.test/shop

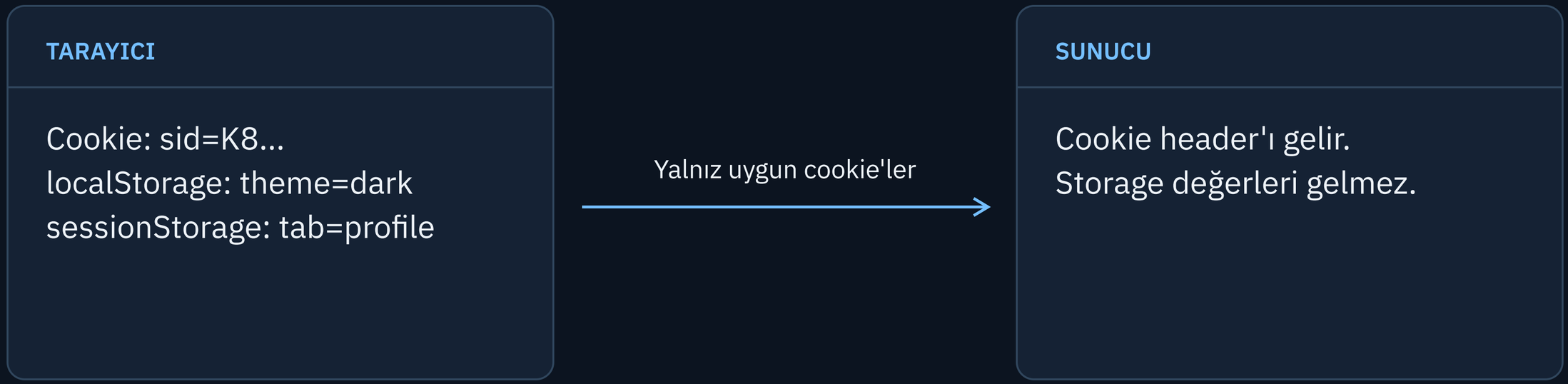
Bu isteğe eklenmez

Path eşleşmiyor.

Şematik tarayıcı görünümü

TARAYICIDA SAKLAMA

Storage, cookie gibi otomatik gönderilmez



sessionStorage, sunucudaki session değildir.

TARAYICIDA SAKLAMA

Tercih saklamak, giriş yapmak değildir

Tarayıcı · Console

```
1  localStorage.setItem("theme", "dark");
2  sessionStorage.setItem("activeTab", "profile");
```

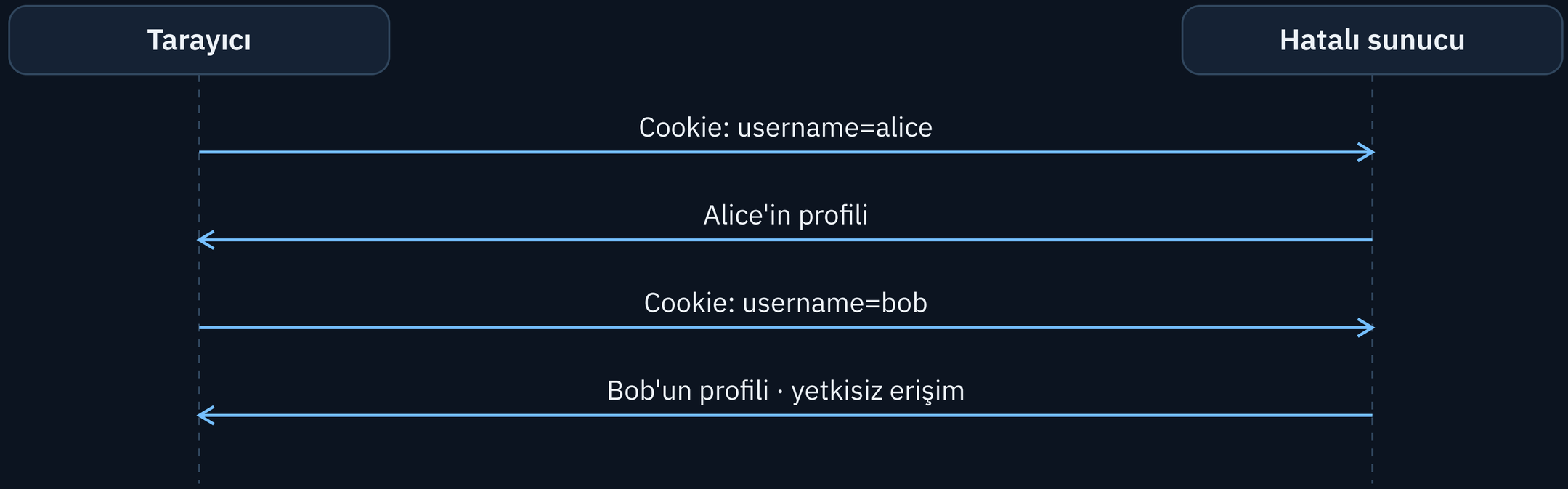
ders.test/profile

Koyu tema · Profil sekmesi

Sunucu, bu değerlerle kullanıcı kimliği doğrulamaz.

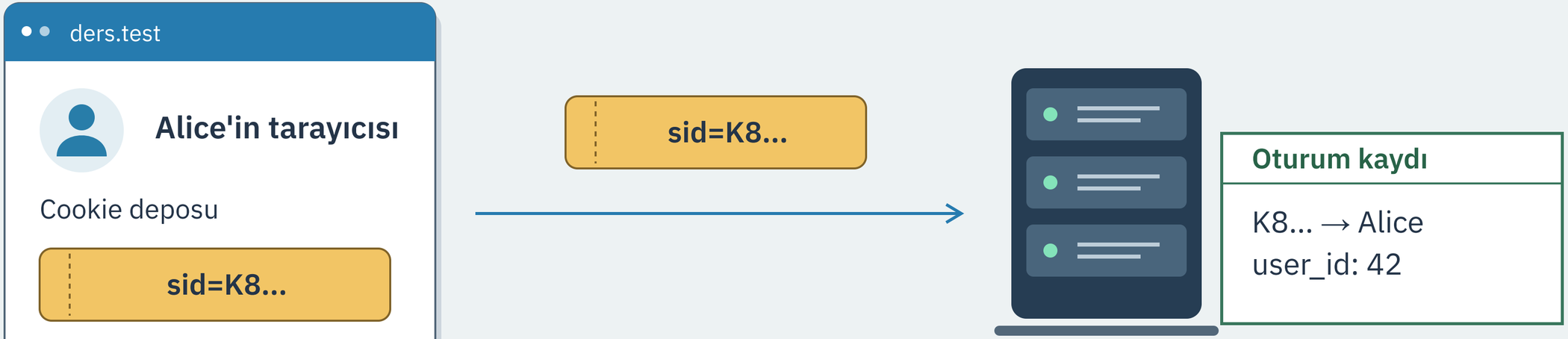
Şematik tarayıcı görünümü

Cookie’ye username=alice yazsak?



SESSION · SUNUCUDA SAKLAMA

Tarayıcı kimliği taşır, kayıt sunucudadır



Kimlik tarayıcıda; oturum kaydı sunucuda.

Oturum verisi imzalı cookie’de taşınabilir



Veri tarayıcıda; doğrulama sunucuda.

Kavramsal gösterim; gerçek cookie biçimi değil.

İMZALI COOKIE

Okumak başka, değiştirmek başka

Orijinal

```
user_id=42 + geçerli imza
→ doğrulama başarılı
```

Değiştirilmiş kopya

```
user_id=7 + eski imza
→ doğrulama başarısız
```

İmza veriyi gizlemez; değişikliği tespit eder.

SESSION · İKİ MODEL

Cookie var. Peki içinde ne var?

SUNUCUDA OTURUM

Rastgele kimlik

sid=K8...

→ sunucudaki kaydı bul

İSTEMCİDE OTURUM

Veri + imza

user_id=42 + imza

→ imzayı doğrula

Cookie bir taşıma mekanizmasıdır; tek başına session modelini söylemez.

PYTHON · FLASK · COOKIE

Bir yanıtta yaz, sonraki istekte oku

Tema seçimini kaydeden view fonksiyonu

```
response = make_response("Tema kaydedildi")
response.set_cookie("theme", "dark", max_age=86400,
                    secure=True, httponly=True, samesite="Lax")
return response
```

Sonraki isteği işleyen view fonksiyonu

```
theme = request.cookies.get("theme", "light")
```

Cookie: theme=dark · Tarayıcıda saklanır; kullanıcı değiştirebilir.

Aynı işlem: Response yazar, Request okur

Controller · tema seçimini kaydeden action

```
Response.Cookies.Append("theme", "dark", new CookieOptions {
    Secure = true, HttpOnly = true,
    SameSite = SameSiteMode.Lax, MaxAge = TimeSpan.FromDays(1)
});
```

Controller · sonraki isteği işleyen action

```
var theme = Request.Cookies["theme"] ?? "light";
```

Cookie yoksa light. Bu değer kullanıcı kimliği değildir.

PYTHON · FLASK · SESSION

Önce imza anahtarını ve cookie ayarlarını ver

app.py · başlangıç

```
app = Flask(__name__)
app.config.update(
    SECRET_KEY=os.environ["FLASK_SECRET_KEY"],
    SESSION_COOKIE_SECURE=True,
    SESSION_COOKIE_HTTPONLY=True,
    SESSION_COOKIE_SAMESITE="Lax",
)
```

Güçlü, gizli anahtar ortamdan gelir. Uygulama HTTPS üzerinden çalışır.

PYTHON · FLASK · SESSION

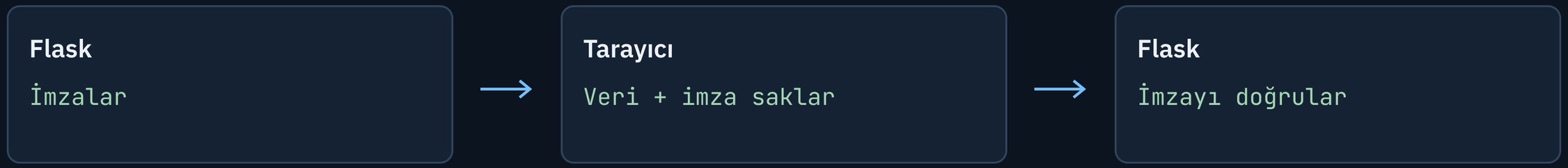
Sözlüğe yazdık; veri imzalı cookie'ye gitti

Tema seçimini kaydeden view · yaz

```python
session["theme"] = "dark"
```

Sonraki view · oku

```python
theme = session.get("theme", "light")
```



İmzalı ≠ şifreli. sessionStorage ile ilgisi yok.

C# · ASP.NET CORE · SESSION

Oturum için sunucuda bir depo aç

Program.cs · session kurulumundan kesit

```
var builder = WebApplication.CreateBuilder(args);
builder.Services.AddDistributedMemoryCache();
builder.Services.AddSession(options ⇒ {
    options.Cookie.SecurePolicy = CookieSecurePolicy.Always;
    options.Cookie.HttpOnly = true;
    options.Cookie.SameSite = SameSiteMode.Lax;
});
var app = builder.Build();
app.UseSession();
```

Bu örnekte depo uygulamanın belleği. Cookie yalnız oturum kimliğini taşır.

C# · ASP.NET CORE · SESSION

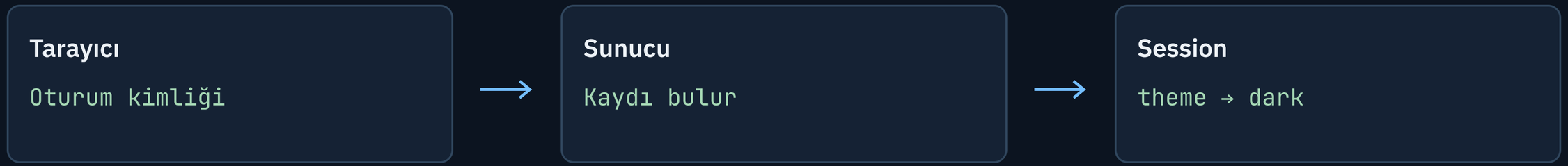
Sözlüğe yazdık; veri sunucudaki depoda kaldı

Controller · tema seçimini kaydeden action

```
1  HttpContext.Session.SetString("theme", "dark");
```

Controller · sonraki action

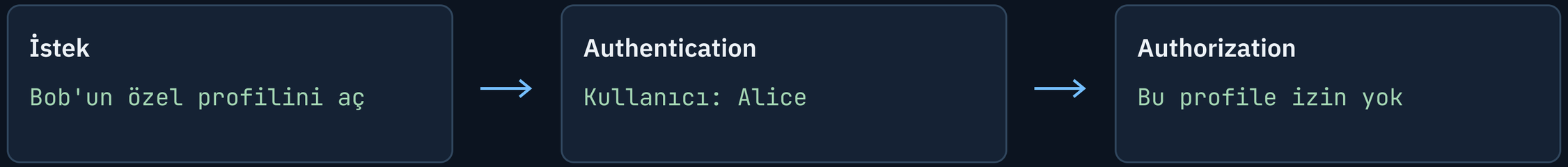
```
1  var theme = HttpContext.Session.GetString("theme") ?? "light";
```



ASP.NET Core Session, kullanıcıyı authenticate etmez.

AUTHENTICATION / AUTHORIZATION

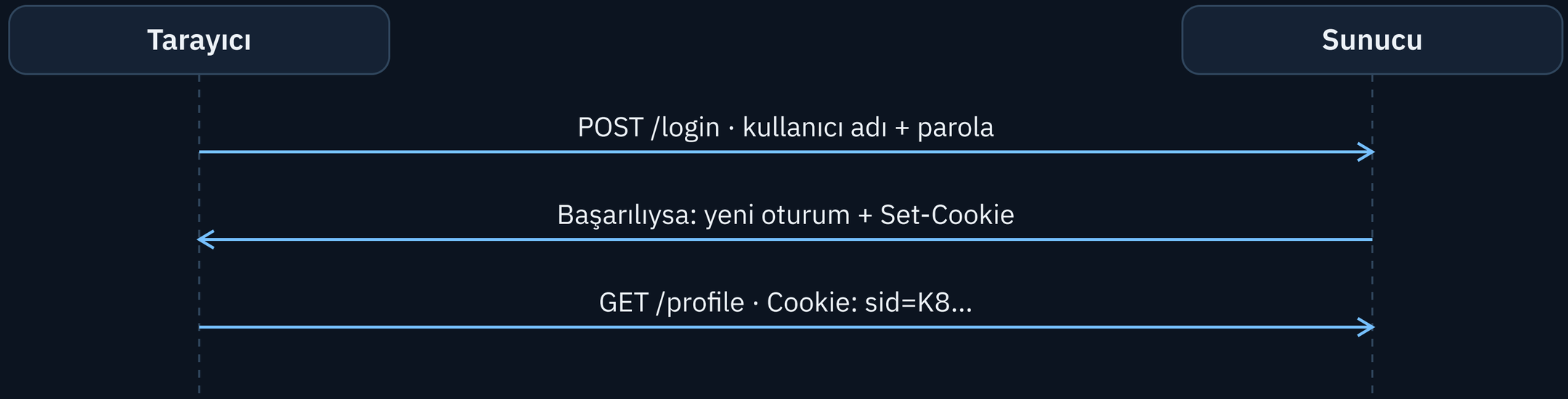
Kim olduğun ve ne yapabileceğin ayrı sorular



Giriş yapmak, her kayda erişim hakkı vermez.

GİRİŞ

Parolayı doğrula, yeni oturum oluştur



Parolanın kendisi cookie'ye yazılmaz.

OTURUMLU İSTEK

Cookie geldi diye doğrudan güvenmeyiz

Kısaltılmış istek

```
1  GET /profile HTTP/1.1
2  Cookie: sid=K8...
```

1 · Oturum

Geçerli mi?

→

2 · Kullanıcı

Kim?

→

3 · İzin

Bu kaynağa erişebilir mi?

OTURUM ÖMRÜ

İki ayrı saat çalışır

TARAYICIDA

Cookie ne kadar kalır?

Max-Age / Expires

SUNUCUDA

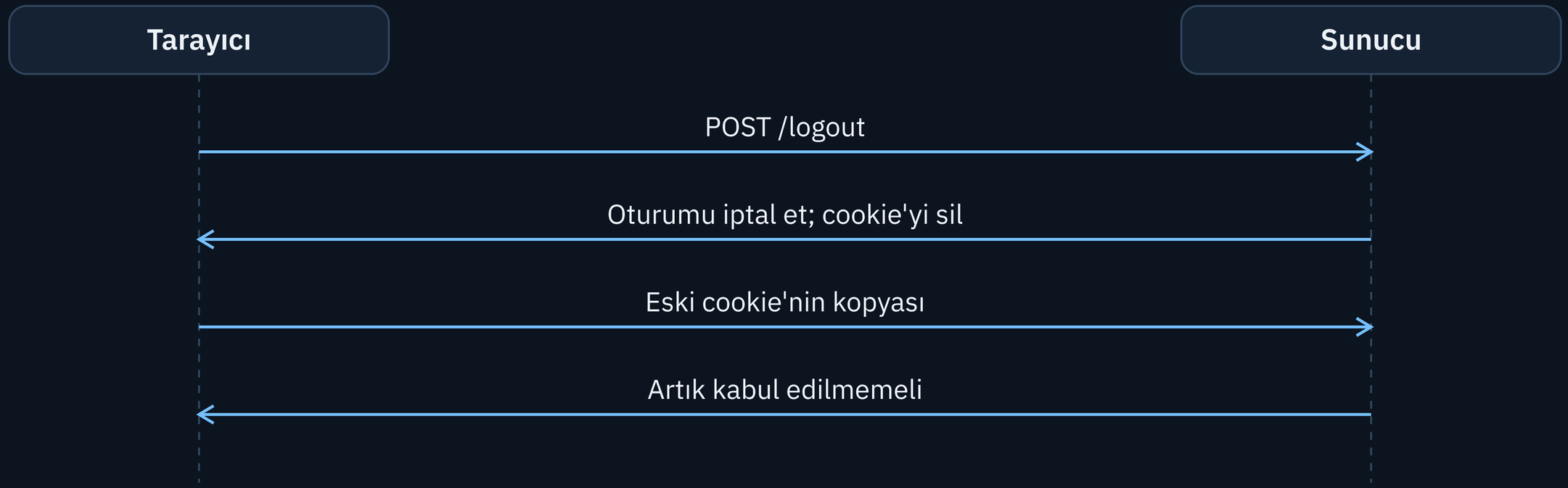
Oturum hâlâ geçerli mi?

Süre / iptal kontrolü

Tarayıcıyı kapatmak güvenilir bir çıkış işlemi değildir.

ÇIKIŞ

Tarayıcıdan sil; sunucuda geçersiz kıl



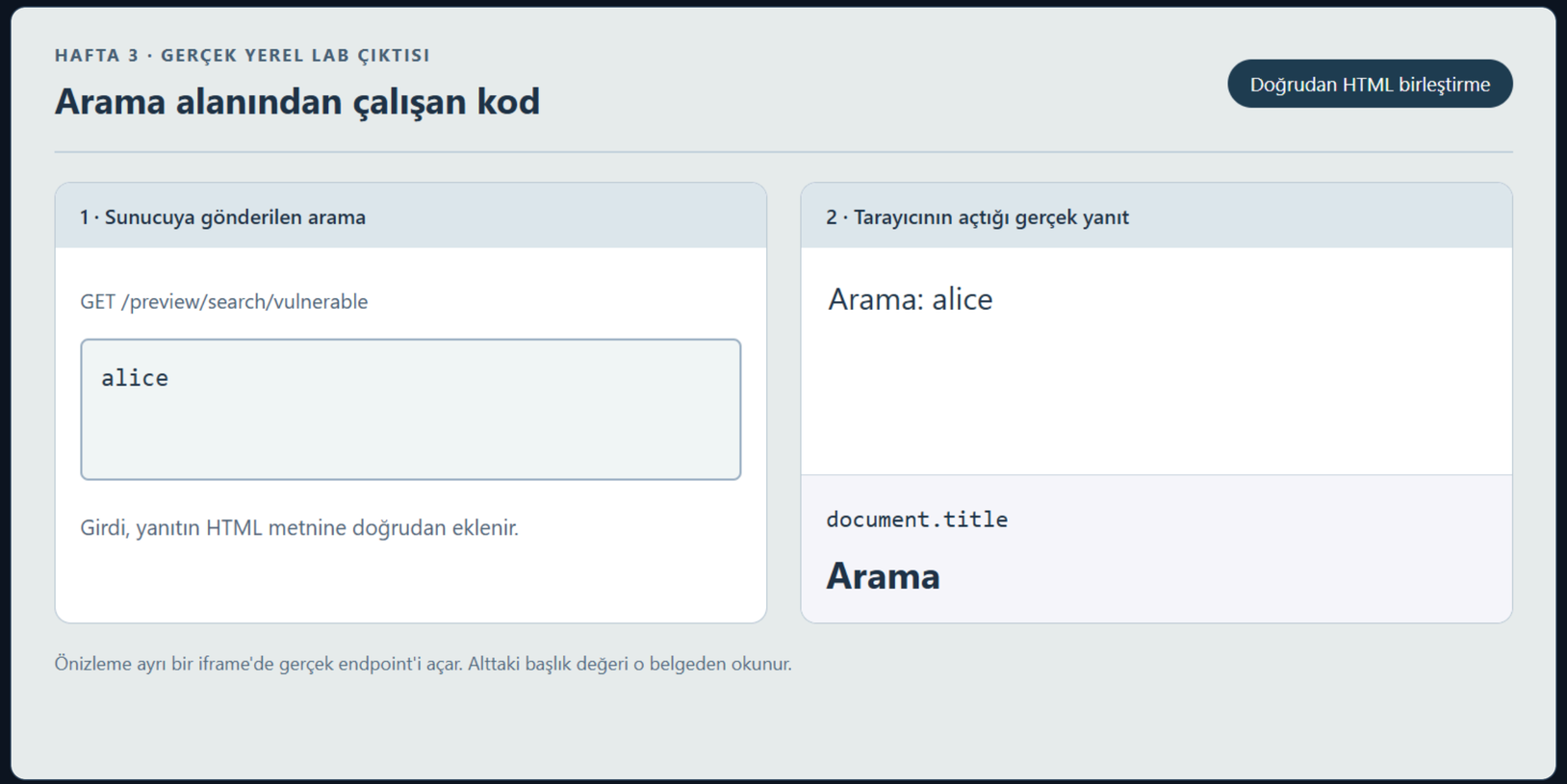
Metin diye aldık, tarayıcı kod diye çalıştırdı



Hafta 2'de SQL ve shell; burada HTML ve JavaScript.

XSS · LAB · NORMAL GİRDİ

Önce alice aratalım



Gerçek lab: arama metni görünür, belge başlığı Arama kalır.

XSS · REFLECTED

Arama metni HTML’e doğrudan ekleniyor

app.py · zafiyetli

```
1  term = request.args.get("q", "")
2  return "<p>Arama: " + term + "</p>"
```

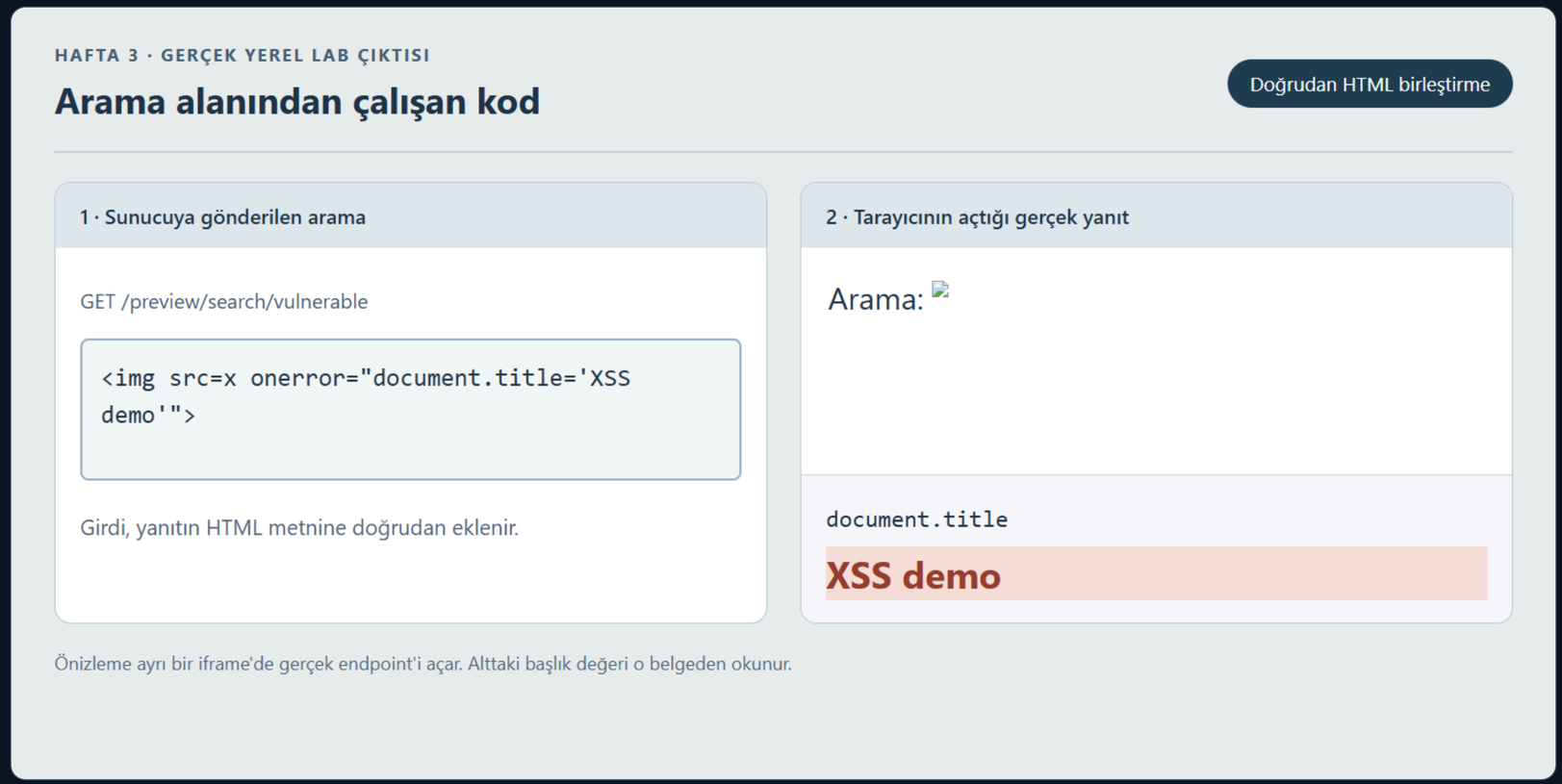
q değeri · yalnız yerel ders örneği

```
1  <img src=x onerror="document.title='XSS demo'">
```

Beklenen

Arama metni

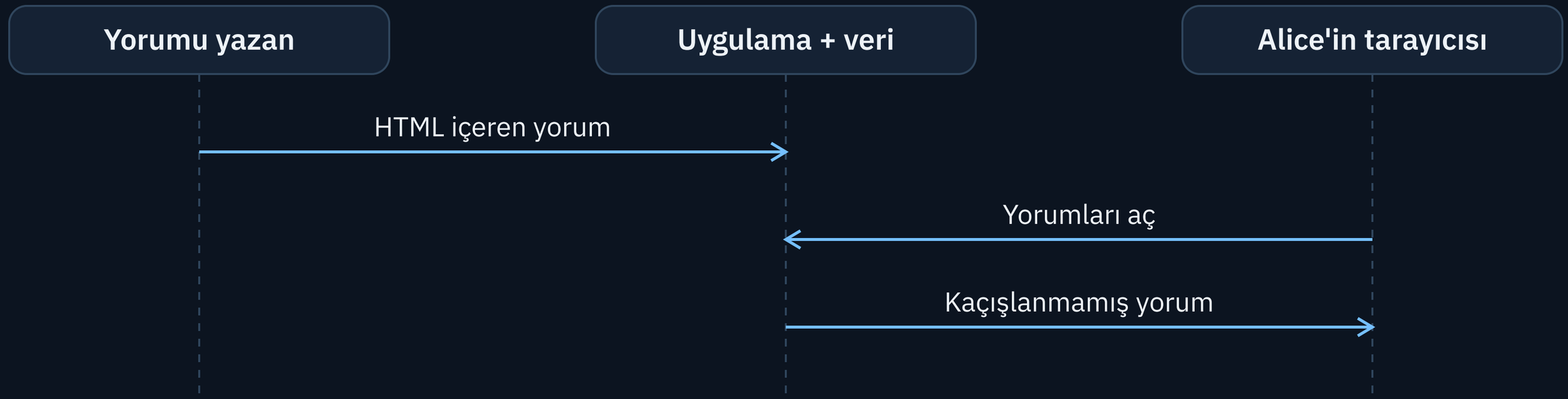
Yalnızca arama yaptık; sayfanın başlığı değişti



Gerçek lab: onerror çalıştı; document.title artık XSS demo.

XSS · STORED

Yorum kaydedilir; sonraki ziyaretçide çalışır



Veritabanına kaydetmek, girdiyi güvenilir yapmaz.

XSS · DÜZELTME

Metni HTML olarak ayrıştırma

app.py · sabit şablona veri gönder

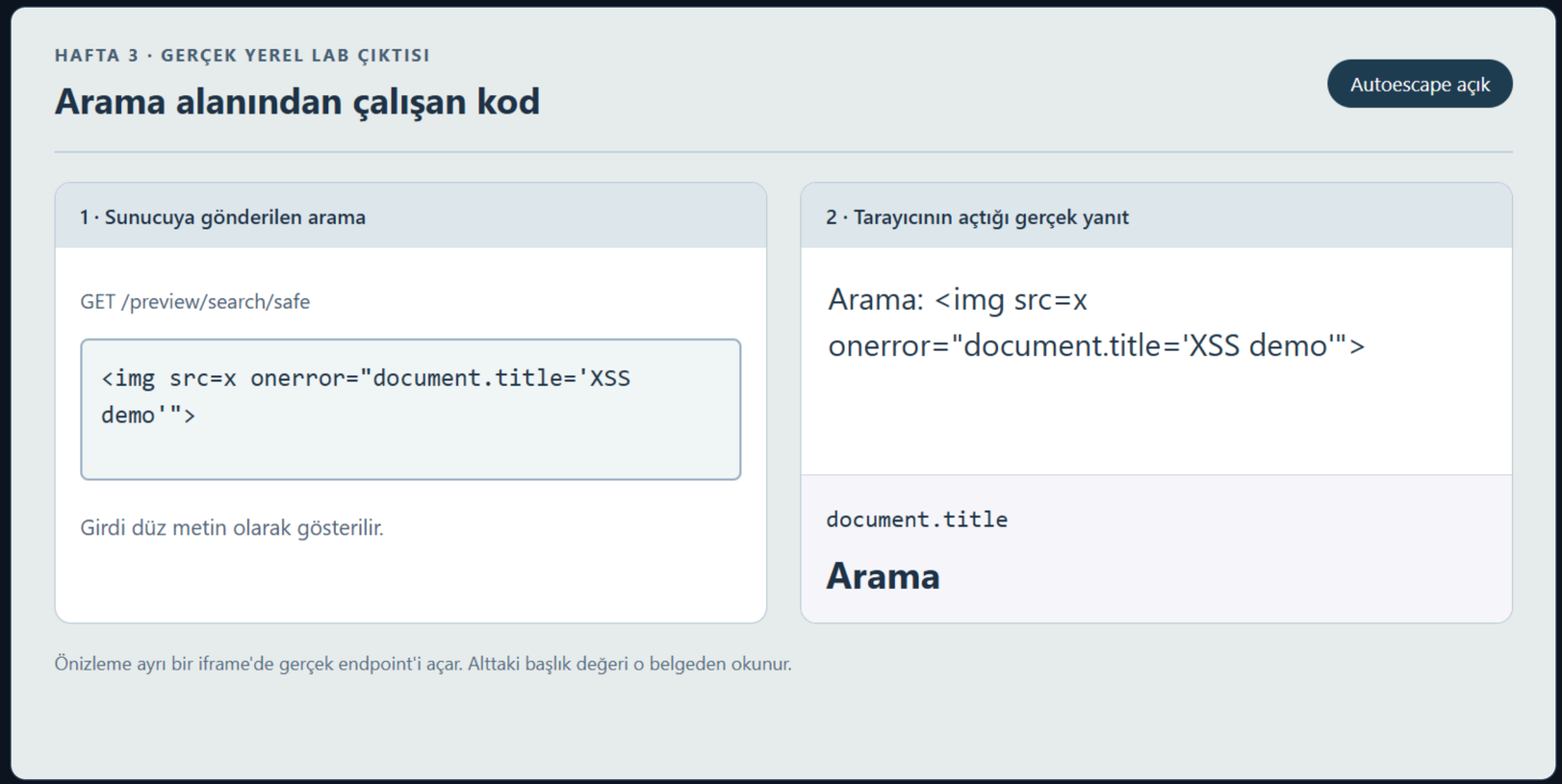
```
1  return render_template("search.html", term=term)
```

search.html · autoescape açık

```
1  <p>Arama: {{ term }}</p>
```

Şablon sabit; arama metni veri olarak eklenir.

Aynı girdi bu kez metin olarak görünüyor



Gerçek lab: HTML kaçışlama açık; img oluşmadı, başlık değişmedi.

HTML kaçışlama, URL'yi güvenli yapmaz

Autoescape açık şablon

```
<a href="{{ url }}">Profil</a>
```

İzin verilmemesi gereken URL scheme'i

```
javascript:alert("demo")
```

URL için ayrıca izin verilen scheme'leri doğrula.

Nonce eşleşen script çalışır

HTTP response header

```
Content-Security-Policy: script-src 'nonce-DEMO_NONCE'; object-src 'none'
```

İzin verilen script

```
<script nonce="DEMO_NONCE" src="/app.js"></script>
```

Inline onerror engellenir. CSP, çıktı düzeltmesinin yerine geçmez.

KAYNAKLAR · STANFORD CS253

Ders 3 için yararlandığımız bölümler

03 · Same Origin Policy

04 · Cookies and Sessions · 05 · Cookie kapsamı

06 · XSS · 07 · XSS Defenses

Feross Aboukhadijeh · Stanford · Fall 2021

KAYNAKLAR

Tarayıcı ve savunma referansları

MDN · Same-origin policy · CORS

OWASP · XSS Prevention · DOMPurify

DEVTOOLS · YEREL LAB

Cookie ile storage farkını görelim

127.0.0.1:5023 · Console

```
1  document.cookie = "lesson_theme=dark; Path=/; SameSite=Lax";
2  localStorage.setItem("lesson_theme", "light");
3  sessionStorage.setItem("lesson_tab", "profile");
```

Application

Üç depoyu bul

→

Network

Run isteğini aç

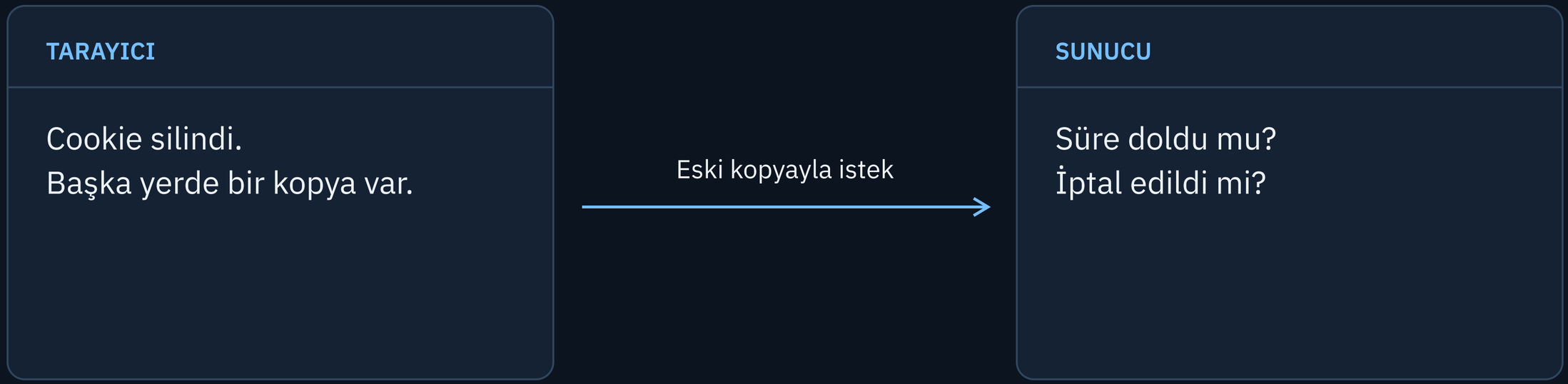
→

Cookie header'ı

Hangisi gönderilmiş?

KONUŞALIM

Çıkış yaptım. Eski cookie işe yarar mı?



KAYNAKLAR

HTTP, cookie ve session

MDN · HTTP · Set-Cookie

MDN · sessionStorage · localStorage

Flask · Sessions

Microsoft Learn · ASP.NET Core Session · Flask · Cookie ayarları

OWASP · Session Management

KAYNAKLAR

Çerez tercihleri ve tarayıcı ayarları

KVKK · 2023/1645 · Çerezler ve açık rıza

MDN · Third-party cookies

Slaytlardaki banner bir öğretim örneğidir; her amaç ayrıca değerlendirilir.

KAYNAKLAR

HTTP durum kodları ve hata yönetimi

RFC 9110 · HTTP Semantics · Status Codes

MDN · HTTP response status codes

RFC 6585 · 429 Too Many Requests

OWASP · Error Handling

Kod tanımı standarttan; endpoint ve yanıt örnekleri ders için hazırlanmıştır.

EK · TARAYICI MODELİ

Origin = scheme + host + port



SOP: Bir origin'deki script, diğer origin'in verisine serbestçe erişemez.

EK · ORIGIN ≠ SITE

İki alt alan adı aynı site olabilir

https://ders.example.test

Ders uygulaması

Origin 1

Şematik tarayıcı görünümü

https://api.example.test

API

Origin 2

Şematik tarayıcı görünümü

İkisi de aynı site: https + example.test